Federação e SSO: O Blueprint de Identidade

Arquitetura, Protocolos e Operações em Access Management (IAM)

Guia de Referência Estruturado para Profissionais de Cibersegurança.



J&J ACELERAÇÃO CYBERSECURITY | EDIÇÃO DE ESTUDO

Gemini Notebook

A Matriz dos Fundamentos

Autenticação (Quem é você?)



Verifica se a pessoa controla os autenticadores associados à identidade apresentada (ex: Senha, Passkey).

Federação (Confiança externa)



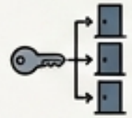
Uma aplicação confia na autenticação emitida por um provedor externo. Baseia-se em acordos e verificações técnicas.

Autorização (O que pode fazer?)



Decide quais recursos e ações uma identidade pode acessar após a entrada no sistema.

SSO (Experiência do Usuário)



Acessar vários serviços com uma única autenticação válida, sem repetir credenciais enquanto a sessão permitir.



Blueprint Concept

A recepção verifica sua identidade (Autenticação) e emite um crachá aceito no prédio (Federação). Cada sala decide se o seu crachá tem permissão para entrar (Autorização).

Gemini Notebook

O Paradigma das Identidades

Identidade Local

Quem Autentica:	A própria aplicação ou seu serviço local.
Credencial:	Compartilhada e verificada dentro do ambiente da aplicação.
Ciclo de Vida:	Exige ação manual em cada sistema isolado.

Identidade Federada

Quem Autentica:	Um Identity Provider (IdP) central confiável.
Credencial:	Verificada apenas pelo IdP; nunca exposta aos aplicativos.
Ciclo de Vida:	Integrado; gerido via provisionamento central.

ALERTA DE ARQUITETURA: SINCRONIZAÇÃO ≠ SSO. Repetir a mesma senha em três telas diferentes é sincronização de credenciais, aumentando a exposição a vazamentos. SSO real ocorre quando uma sessão válida no IdP dispensa novas telas de login nas aplicações seguintes.

Gemini Notebook

A Anatomia da Confiança



Usuário &
Navegador

IdP / OP
(Provedor)

SP / RP
(Aplicação)

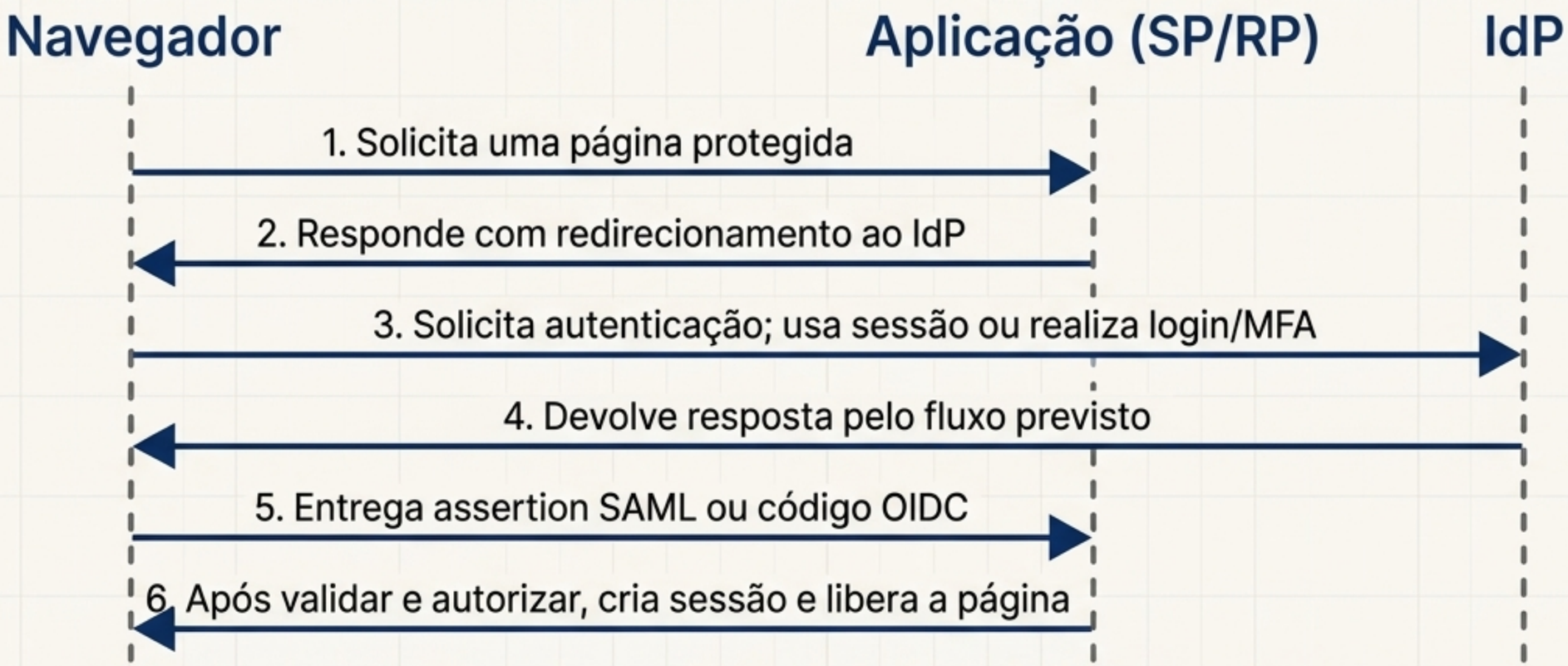
API
(Resource Server)

Usuário & Navegador: A pessoa solicitando acesso e o user agent que transporta mensagens. O navegador apenas transporta; a aplicação valida.	**SP / RP:** A aplicação que aceita a autenticação externa (Service Provider em SAML; Relying Party em OIDC).
IdP / OP: Autentica o usuário, aplica políticas e emite informações verificáveis.	**API:** Serviço que aceita tokens para operações autorizadas (cenário OAuth).

A Base da Confiança: A relação não é automática. Requer metadados XML (SAML) ou Discovery/JWKS (OIDC) para definir emissores válidos (Issuer) e chaves públicas para verificar assinaturas.

Gemini Notebook

O Fluxo Universal de SSO

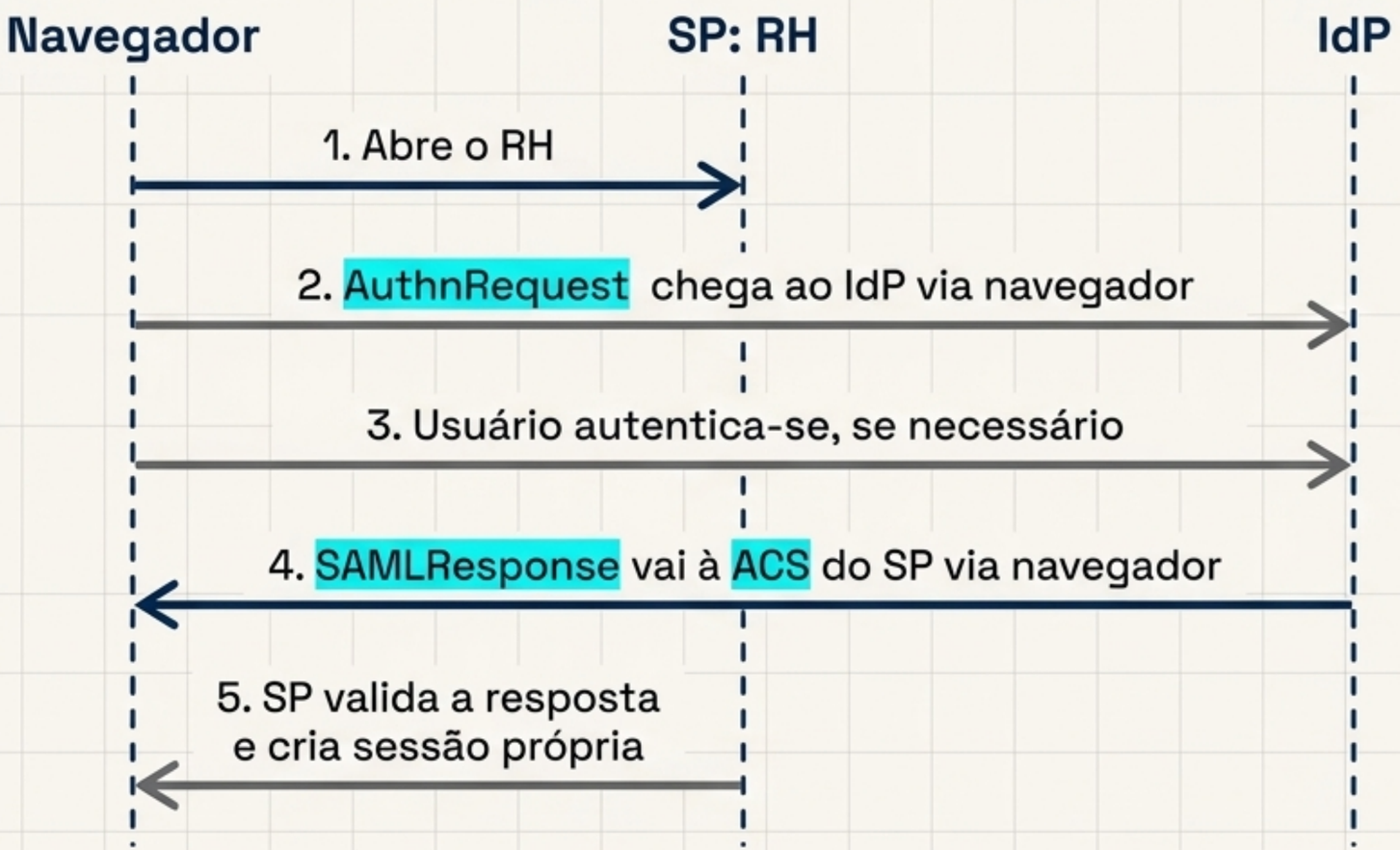


Nota de Engenharia: Uma sessão aberta no IdP (Passo 3) é o motor que evita uma nova tela de senha ao acessar a segunda aplicação.

Gemini Notebook

O Motor Enterprise: SAML 2.0

Federação baseada em Assertions via XML.



ALERTA DE VALIDAÇÃO

Assinatura ≠ Confiança Cega.

A assinatura garante a integridade e a origem, mas o SP deve validar rigidamente:

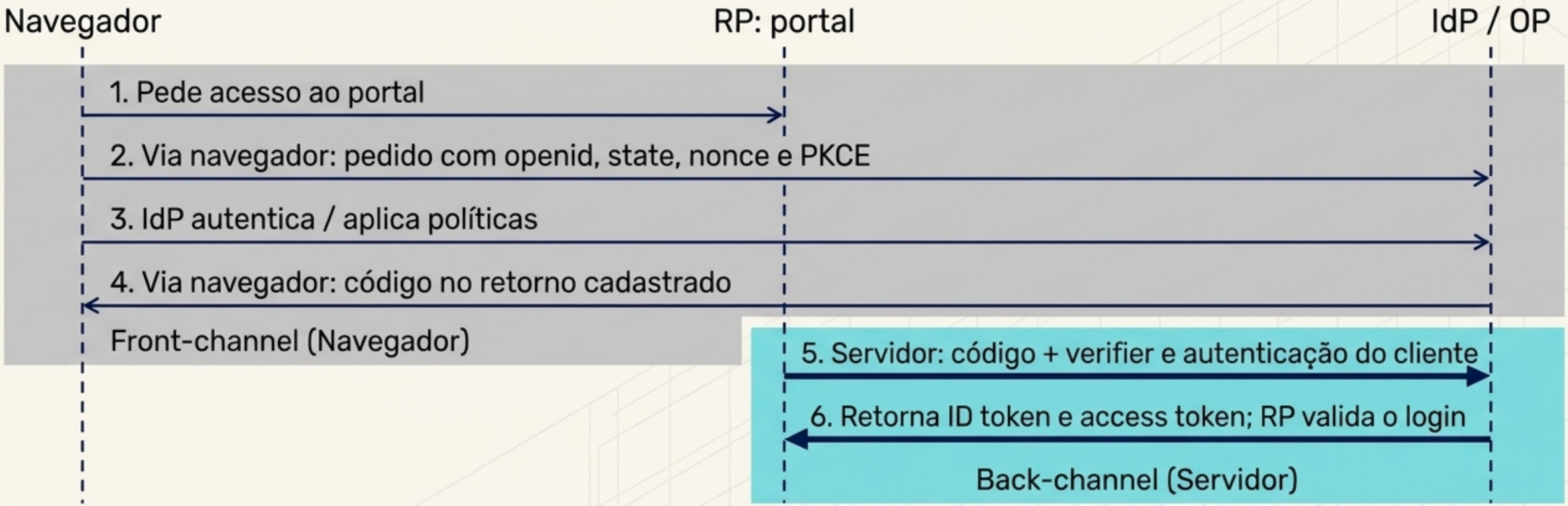
- O Destinatário (Audience)
- A URL de retorno (ACS)
- O Emissor
- A Janela de Tempo

Assinatura não criptografa o conteúdo em XML.

Gemini Notebook

A Camada Moderna: OpenID Connect (OIDC)

Identidade construída sobre o framework OAuth 2.0.

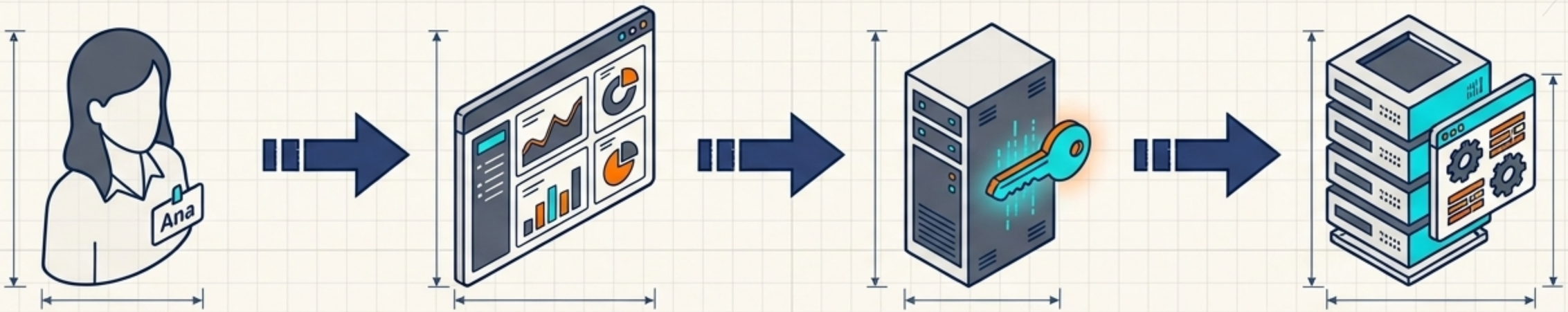


ID Token (JWT):	PKCE, Nonce, State:
Prova de autenticação consumida pela RP.	Proteções criptográficas que vinculam a resposta à navegação original, bloqueando interceptações.

Gemini Notebook

REGRA DE OURO: OAuth isolado NÃO é protocolo de login. É um framework de autorização delegada.

Delegação Segura: OAuth 2.0



Resource Owner: A usuária (Ana) que autoriza o acesso.

Client: Ferramenta de relatórios (solicita acesso).

Authorization Server: Avalia a concessão e emite o token.

Resource Server (API): Verifica o token e libera apenas os dados permitidos.

Escopos (Scopes)

O Access Token funciona como uma chave de hotel restrita. Um escopo (ex: treinamentos.read) limita o privilégio do token. A ferramenta pode ler o histórico de treinamentos de Ana, sem ter acesso à senha dela ou permissão para alterar notas.

Gemini Notebook

A Matriz de Decisão dos Protocolos

	SAML 2.0	OIDC	OAuth 2.0
Finalidade	Federação e SSO web por assertions.	Autenticação federada e identidade sobre OAuth.	Delegação e controle de acesso a recursos/APIs.
Artefato central	Assertion em XML, em uma resposta SAML.	ID token; usa também artefatos OAuth.	Access token; pode haver refresh token.
Formato	XML.	ID token em JWT.	Access token pode ser opaco ou JWT.
Quem consome	SP valida a mensagem/assertion.	RP valida o ID token.	API valida o access token.
Atenção	Assinatura não substitui audience e destinatário.	ID token não é credencial de acesso genérica a APIs.	OAuth sozinho não é protocolo padronizado de login.

Gemini Notebook

Inspeção de Artefatos de Segurança

Assinatura e Chave:
A mensagem foi íntegra e emitida por uma origem confiável, usando algoritmo e chave correta?

Destinatário (aud):
Este artefato foi emitido especificamente para este consumidor (client_id)?



Emissor (iss):
É exatamente o provedor esperado para esta integração?

Tempo (exp, nbf):
O artefato está dentro da validade (considerando tolerância de relógios)?

Sujeito (sub):
A identidade está associada à conta correta, no contexto do emissor?

Fluxo e Reutilização:
A resposta corresponde ao pedido original e não é um ataque de replay?

Lembrete: Assinatura não é criptografia. Um JWT assinado pode ser lido em texto claro se interceptado.

Gemini Notebook

Engenharia de Acesso: Login vs. Provisionamento

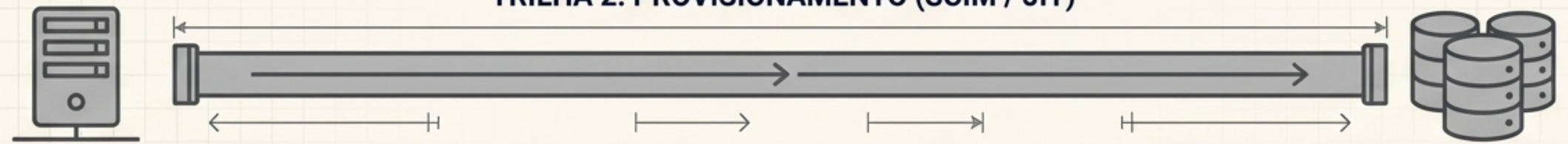
Plataformas como Entra ID, Google Workspace e Okta atuam como o **Hub Central de identidade,** mas o acesso depende de dois caminhos independentes:

TRILHA 1: AUTENTICAÇÃO (SAML / OIDC)



Ocorre via Navegador (Foreground). Valida a identidade e estabelece a sessão no exato momento do acesso.

TRILHA 2: PROVISIONAMENTO (SCIM / JIT)

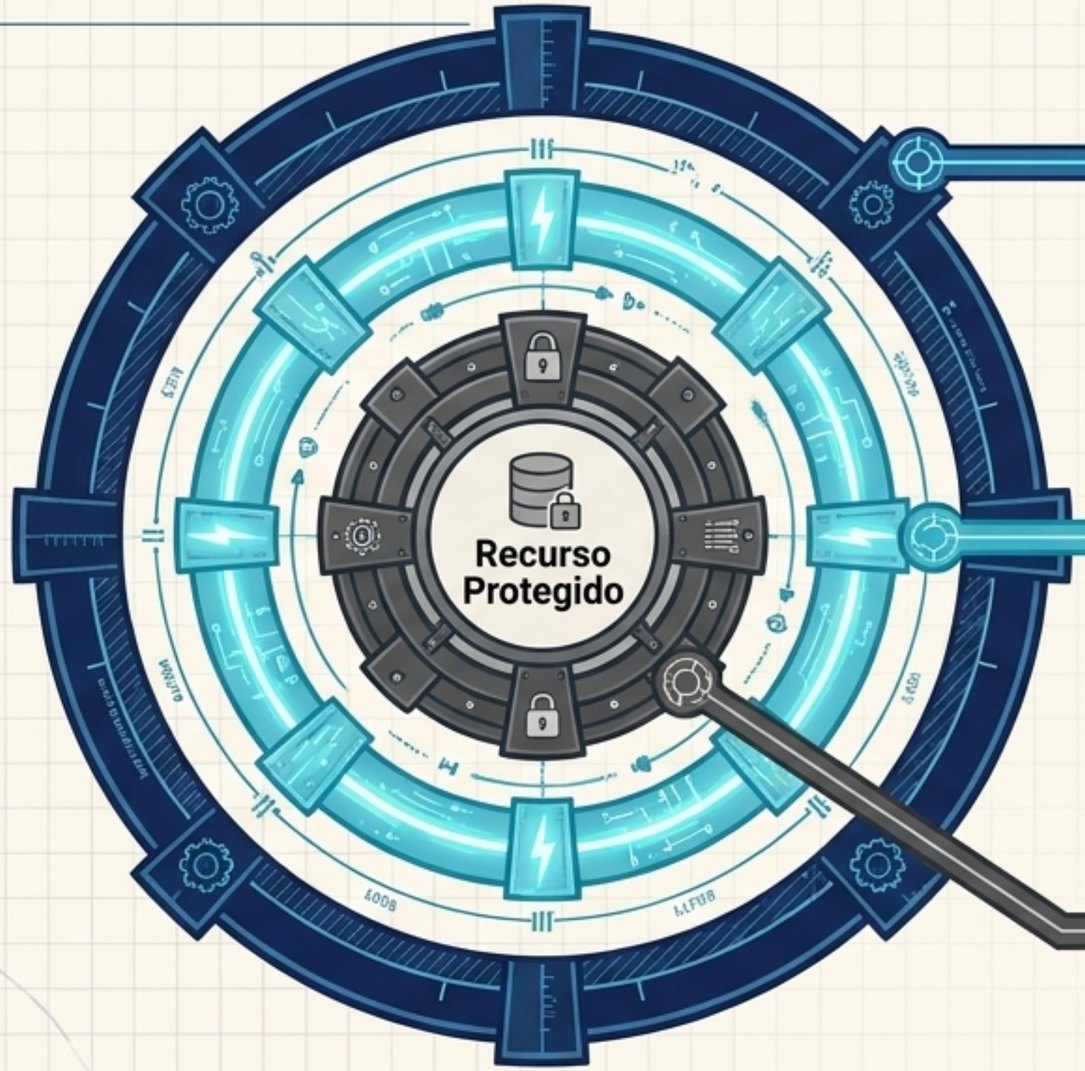


Ocorre via API/Servidores (Background). SCIM padroniza operações para criar, atualizar e excluir contas sem intervenção do usuário.

⚠ **Nota Crítica:** Se o conector SCIM falhar, uma pessoa desligada no IdP ainda pode ter uma conta ou sessão válida retida localmente na aplicação.

Gemini Notebook

Defesa em Camadas no IAM



1. MFA Resistente a Phishing

Combina algo que você sabe, possui ou é. Fatores modernos (FIDO2, Passkeys) evitam que o usuário seja enganado por sites falsos. Duas senhas não representam dois fatores.

2. Acesso Condicional (Contexto)

Avalia sinais dinâmicos antes de permitir acesso.

Exemplo: Exigir que o dispositivo seja gerenciado (MDM) para abrir dados de RH.
Localização sozinha não comprova identidade.

3. Menor Privilégio

SSO simplifica a entrada, mas não significa acesso irrestrito. Separe contas administrativas das operacionais. Exija reautenticação para aprovações sensíveis, mesmo com a sessão aberta.

Gemini Notebook

O Ciclo de Vida da Identidade

Admissão

IdP central cria a identidade → SCIM provisiona as contas locais → Usuário recebe acesso e configura MFA.

Mudança (Movimentação)

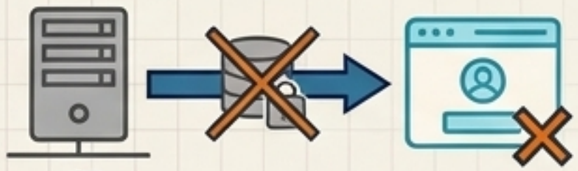
Validar nova função: remover direitos antigos desnecessários + aprovar novos. Evitar acúmulo de privilégios.

Desligamento

⚠ Bloquear a conta no IdP é apenas o passo 1. A aplicação local ainda pode manter o acesso.

O Desafio Crítico: Logout vs. Revogação

Sessão do IdP:
Encerrá-la impede novos logins corporativos centrais.



Sessão da Aplicação:
Mantida localmente pelo SP. Pode sobreviver ao bloqueio do IdP sem um fluxo de Single Logout.



Tokens de API:
Um Access Token válido continuará sendo aceito até expirar (ex: 10h15), mesmo se o IdP for bloqueado às 10h05.



Gemini Notebook

Mapa de Ameaças em Federação

	Ameaça	Consequência	Controle
	**Conta Central Comprometida**	O invasor pode alcançar vários serviços atribuídos à identidade via SSO.	MFA resistente a *phishing*, menor privilégio, proteção de administradores.
	**Confiança Incorreta**	Aplicação aceita emissor, chave, destinatário ou URL de retorno indevido.	Revisão rígida de metadados, restrição de URLs (Redirect URI).
	**Tokens e Assertions Expostos**	Artefatos copiados via logs ou rede podem permitir acesso indevido.	HTTPS obrigatório, validade curta, PKCE, ausência de segredos em logs.
	**Contas Órfãs** (Desligamentos)	Pessoa desligada ou transferida mantém direitos e sessões na aplicação local.	Desprovisionamento ativo via SCIM, reconciliação de contas e auditoria.

Gemini Notebook

Telemetria, Correlação e Auditoria

Para descobrir onde um fluxo quebrou, correlacione identificadores exatos e timestamps entre os sistemas.

Log do IdP (Autenticação)

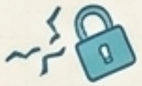
Sucesso/falha de login, exigência e resultado de MFA, política condicional aplicada, fuso horário e contexto permitido.





Log do SP / API (Validação)

Rejeição do fluxo de federação, erro na validação da assinatura ou do token, criação de sessão local, negação por falta de escopos.


Log de Provisionamento (SCIM)

Criação/desativação de contas, falhas de sincronização de conectores, horário da última execução no destino.





CAIXA VERMELHA DE AUDITORIA (NUNCA LOGAR):



- Senhas (mesmo que com hash)
- Tokens completos (Access, ID, Refresh)
- Cookies de sessão ativos
- Atributos pessoais desnecessários

Apenas registre que a validação ocorreu com sucesso ou falha, nunca grave a credencial ou o segredo no log.

Gemini Notebook